

Assignment 03: General Assessment

Question 1: What is/are SDU's ip address range/s?

SDU uses different IP address ranges depending on the service provided. We can distinguish two ranges:

- Externally hosted services like www.sdu.dk fall into 52.224.0.0 - 52.255.255.255 network range.
- Self-hosted services like nextcloud.sdu.dk run on SDU's own RIPE IP block, which is 130.225.0.0 - 130.224.255.255.

Question 2: What differences do you observe for operations of www.sdu.dk and nextcloud.sdu.dk?

At the operational level of the commands (like `whois` and `dig`), no difference was identified. Both of them were resolved to their respective IP addresses using the `dig` command. After that, using `whois` command we obtained all the information related to the two services.

However, the real difference lies in infrastructure ownership and hosting. www.sdu.dk is hosted externally on Microsoft Azure, whereas nextcloud.sdu.dk is provided by SDU's own network.

Question 3: Using `nmap's --ip-options` argument allows to manipulate options in the ip header of packets sent. (Yes/No)

Yes.

Question 4: `nmap's --spoof-mac` argument allows to imitate:

- a) another host's ip address.
- b) another host's hardware address.

Answer: b) another host's hardware address.

Question 5: Comparing `nmap` and `GVM`, when would you use which tool? Where do you see the biggest advantages?

On one hand, we have `Nmap`, a network scanning tool mainly used for initial discovery and inspecting a target host's subnet. We can obtain a very good overview of a host's structure, like port states, services running on them, OS detection, version detection and so on (the amount of information achieved depends on the type of scan executed). `Nmap's` biggest advantage is its speed and lightweight footprint; it has a minimal network disruption, reducing drastically the likelihood of being detected by security systems. You would use `Nmap` during the early discovery phases of an attack or assessment to map out the target host's subnet.

On the other hand, we have `GVM`, which provides a deep vulnerability evaluation. Its biggest advantage is the ability to correlate together exposed services with a massive database of network vulnerability tests (CVE/NVT), resulting in detailed reports that provide actionable remediation steps. You would use `GVM` to determine attack surfaces and identify vulnerabilities of the target system. While it requires significantly more time and system resources than `Nmap`, the tradeoff is a comprehensive and exhaustive vulnerability assessment, where depth takes priority over stealth.

Question 6: List 4 services from the Metasploitable Linux VM, detailing service, port number and version number.

1. HTTP, port 80, version Drupal 7.5 (running on Apache 2.4.7).
2. SSH, port 22, version OpenSSH 6.6.1p1 (on Ubuntu 14.04).
3. FTP, port 21, version ProFTPD 1.3.5.
4. HTTPS (CUPS), port 631, version CUPS 1.7.2.

Question 7: For each of the vulnerabilities, provide a CVE with a severity rating.

1. HTTP service, [CVE](#), severity 10.
2. SSH service, [CVE-1999-0501](#), severity 9.8.
3. FTP service, [CVE-1999-0502](#), severity 7.5.
4. HTTPS service, [CVE-2016-2183](#), severity 7.5.

Question 8: For one of these vulnerabilities, explain the underlying issue. What can be achieved? How severe is that issue – do not just use GVMs severity rating. Instead explain why you think this issue is severe, based on the possible impact.

Keep this short, i.e., one sentence per vulnerability.

1. HTTP service, an attacker can exploit this vulnerability remotely, without authentication, to run code on the web server, allowing a full compromise of the host, including data theft and internal network pivoting.
2. SSH service, an attacker who guesses the default/known credentials, which have never been changed, obtains a valid SSH shell, leading to a complete control of the host.
3. HTTPS service, an attacker with a Man-in-the-Middle position can capture a large amount of ciphertext from the session recovering plaintext data from it, breaking confidentiality of the transmission.
4. FTP service, an attacker who obtain a valid access using default/known credentials can upload, download or delete files on the server, planting malicious files for further attacks.

Question 9: Create a final report, extending the collected information with an overall review of the security concerns in the Metasploitable system, e.g., different criticality levels of the services and which ones to prioritise when addressing security issues (a selection of the most relevant issues for prioritisation limited to the 4 vulnerable services you selected). For this use a combination of the results from the tools that you used or one of the tools.

Note, that you shouldn't just copy & paste the severity of the tools you use, but read through the CVE you selected and try to determine how critical it is. I.e., what is the possible impact? Is the service inoperable, or is intellectual property at risk?

The Metasploitable virtual machine shows a critically low security level, exposing multiple unsecured services to the local subnet without any firewall segmentation. Since default administrative credentials are very simple to guess/obtain, an attacker can easily achieve a complete control of the host with minimal effort, including running arbitrary code on the web server, executing a valid SSH shell, recovering plaintext data from HTTPS sessions and uploading, downloading or deleting files on the server.

The priority of remediation measures should be as follows (taking into account CVSS severity level):

1. Drupal, requires no authentication and allows to run arbitrary code remotely, defining an immediate threat for complete host takeover.
2. OpenSSH, ensures an easy access to a valid SSH shell, leading to local privilege escalation, even though it requires the attacker to guess or brute-force the credentials of the target host.
3. ProFTPD, exposes local files and allows malicious file uploads. By the way, it doesn't have the same vulnerable severity as described before, since the attacker is restricted to file operations.
4. CUPS, man-in-the-middle situation where the attacker can obtain plaintext data from a huge amount of ciphertext taken from a HTTPS transmission session. However, this type of vulnerability does not pose an immediate threat to the target system.

Question 10: What does a version number actually tell you? In the Lecture 3 demo, vsftpd 2.3.4 had the "right" version but was a back-doored build. Metasploitable ships software you were told to treat as hostile. (a) How far can version-based findings from nmap and GVM be trusted? How could an assessor check what is really running? (b) Which tools and images did you have to trust yourself, such as the Kali image or the GVM feed, and how could that trust be established? Relate your answer to the CIA triad. (max two short paragraphs)

- a) Version numbers reported by network tools like Nmap and GVM are just what the software claims to be, not whether the binary code is reliable. Since version-based findings can be easily faked, hidden by administrators or injected with back-doors (like vsftpd 2.3.4), they cannot be trusted intrinsically. A system administrator or an assessor shouldn't trust the banner, but actively verify the binary hash and observe its runtime behaviour.
- b) During the evaluation, we had to trust the Kali image, the GVM feed and scanning tools like Nmap. If any of these were altered, we can safely say that CIA triad could be affected, including leaked data, broken tooling or incorrect results. Trust can be established by checking the signatures of these tools, downloading them from official sources and using package-manager verification, such as apt.